

CYBERSECURITY PORTFOLIO PROJECT

Network Reconnaissance Report

Nmap-Based Vulnerability Assessment of a Lab Target

Mahesh Bhausaheb Jadhav

maheshbjadhav8767@gmail.com | linkedin.com/in/mahesh-jadhav-31805522a

Target	192.168.203.128 (Metasploitable2)
Assessment Type	Network Reconnaissance & Vulnerability Scanning
Tool Used	Nmap (with NSE scripts)
Environment	Isolated Lab (VirtualBox, Host-only Network)
Classification	Educational / Portfolio Project

Disclaimer: All scanning and testing activity documented in this report was performed in an isolated virtual lab environment against Metasploitable2, a machine intentionally built to be vulnerable for training and educational purposes. No unauthorized systems were accessed or scanned.

1. Executive Summary

This report documents a structured network reconnaissance and vulnerability assessment performed against a single lab target using Nmap. The engagement followed a seven-stage methodology covering host discovery, port scanning, service and version detection, OS fingerprinting, NSE-based vulnerability scripting, and firewall detection. The assessment identified approximately 20 open ports, several of which expose critical, publicly known vulnerabilities including a confirmed remote root backdoor. Findings are ranked by severity below, along with remediation guidance for each.

2. Scope

The scope of this assessment was limited to a single host (192.168.203.128) running Metasploitable2 on an isolated host-only virtual network. Testing was passive-to-semi-active in nature, limited to Nmap scanning and its bundled NSE vulnerability scripts. No exploitation or post-exploitation activity was performed beyond what Nmap's scripts execute automatically for vulnerability confirmation.

3. Methodology

3.1 Host Discovery

```
nmap -sn 192.168.203.0/24
```

Identified live hosts on the subnet prior to targeted scanning.

3.2 Port Scanning

```
nmap -p- 192.168.203.128 -oN port_scan.txt
```

Full scan of all 65,535 TCP ports. Approximately 20 ports were found open.

3.3 Service & Version Detection

```
nmap -sV 192.168.203.128 -oN service_version.txt
```

Identified exact software and version strings for each open port, enabling CVE mapping.

3.4 OS Detection

```
nmap -O 192.168.203.128 -oN os_detection.txt
```

Fingerprinted the target operating system via TCP/IP stack behavior analysis.

3.5 NSE Script Scanning

```
nmap --script vuln 192.168.203.128 -oN nse_vuln_scan.txt
```

Executed Nmap Scripting Engine vulnerability scripts to actively identify exploitable misconfigurations and known CVEs.

3.6 Firewall Detection

```
nmap -sA 192.168.203.128 -oN firewall_detection.txt
```

ACK scan used to distinguish firewall-filtered ports from genuinely closed ports.

3.7 Consolidated Report

```
nmap -A 192.168.203.128 -oA final_report
```

Combined OS detection, service detection, default scripts, and traceroute into a single consolidated evidence file.

4. Key Findings

The following vulnerabilities were identified and confirmed via Nmap NSE scripts, ranked by severity.

Severity	Finding	Port	CVE
Critical	vsFTPD 2.3.4 Backdoor	21/ftp	CVE-2011-2523
Critical	UnrealIRCd Trojaned Backdoor	6667/irc	-
High	RMI Registry Remote Code Execution	1099/java-rmi	-
High	SSL POODLE	25, 5432	CVE-2014-3566
High	CCS Injection	5432	CVE-2014-0224
Medium	Weak Diffie-Hellman Groups	25, 5432	-
Medium	Slowloris DoS	80, 8180	CVE-2007-6750
Medium	CSRF Vulnerabilities	80, 8180	-
Low-Medium	Missing HttpOnly Cookie Flag	8180	-
Medium	Exposed Admin/Manager Interfaces	8180	-

vsFTPD 2.3.4 Backdoor (21/ftp) — Critical

Confirmed exploitable backdoor. NSE script execution returned uid=0(root), confirming remote root access with no authentication.

UnrealIRCd Trojaned Backdoor (6667/irc) — Critical

Known backdoored build of UnrealIRCd allowing remote code execution.

RMI Registry Remote Code Execution (1099/java-rmi) — High

Default RMI registry configuration allows loading of classes from remote URLs, enabling RCE.

SSL POODLE (25, 5432) — High

SSLv3 padding-oracle vulnerability allowing MITM attackers to decrypt data.

CCS Injection (5432) — High

Malformed TLS handshake can trigger use of a zero-length master key, enabling session hijack.

Weak Diffie-Hellman Groups (25, 5432) — Medium

1024-bit DH groups are susceptible to passive eavesdropping (Logjam-class weakness).

Slowloris DoS (80, 8180) — Medium

Web servers vulnerable to resource exhaustion via slow, partial HTTP requests.

CSRF Vulnerabilities (80, 8180) — Medium

Multiple unprotected forms discovered via spidering (TWiki, Mutillidae, Tomcat).

Missing HttpOnly Cookie Flag (8180) — Low-Medium

Session cookies (JSESSIONID) lack the HttpOnly flag, exposing them to potential XSS-based theft.

Exposed Admin/Manager Interfaces (8180) — Medium

Tomcat Manager and numerous guessable /admin/ paths are publicly accessible.

5. Remediation Recommendations

- Immediately patch or remove vsFTPD 2.3.4 and UnrealIRCd — both contain confirmed backdoors.
- Disable legacy, unencrypted services such as Telnet, rexec, rlogin, and rsh.
- Upgrade SSL/TLS configuration to disable SSLv3 and remove weak Diffie-Hellman cipher suites.
- Restrict the RMI registry to trusted hosts only, or disable it if not required.
- Set the HttpOnly and Secure flags on all session cookies to reduce XSS-based session theft risk.
- Remove or properly access-restrict exposed admin and manager interfaces (e.g., Tomcat Manager).
- Apply timeout and rate-limiting protections against Slowloris-style denial-of-service attacks.
- Establish a regular patch management cycle to prevent accumulation of outdated, vulnerable service versions.

6. Conclusion

This assessment demonstrates a complete network reconnaissance methodology, from initial host discovery through active vulnerability identification. The target exhibited multiple critical and high-severity vulnerabilities, most notably a confirmed remote root backdoor via vsFTPD. This reflects the type of findings and reporting expected during the reconnaissance and vulnerability assessment phases of a real-world penetration test.